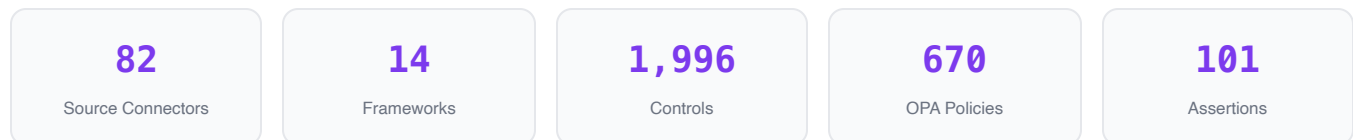




What Warlock Is

Warlock is a governance, risk, and compliance platform built on the premise that compliance is a telemetry problem, not a spreadsheet problem. The traditional GRC workflow asks compliance teams to spend weeks collecting screenshots, exporting CSVs, and assembling evidence binders by hand. By the time that binder reaches an auditor, half the evidence is already stale. Assessments are subjective because two people reviewing the same control can reach different conclusions, and traceability is nonexistent because reconstructing the chain from a raw data source to a compliance determination requires a human to manually piece together artifacts from different systems.

Warlock eliminates all three problems. It continuously ingests security telemetry from the tools an organization already operates, normalizes that data into a universal finding format, maps those findings to compliance controls across fourteen frameworks simultaneously, and produces deterministic assessment results. Every stage of this process is SHA-256 hashed, creating a tamper-evident audit trail that runs from the original API response all the way through to the final control result.



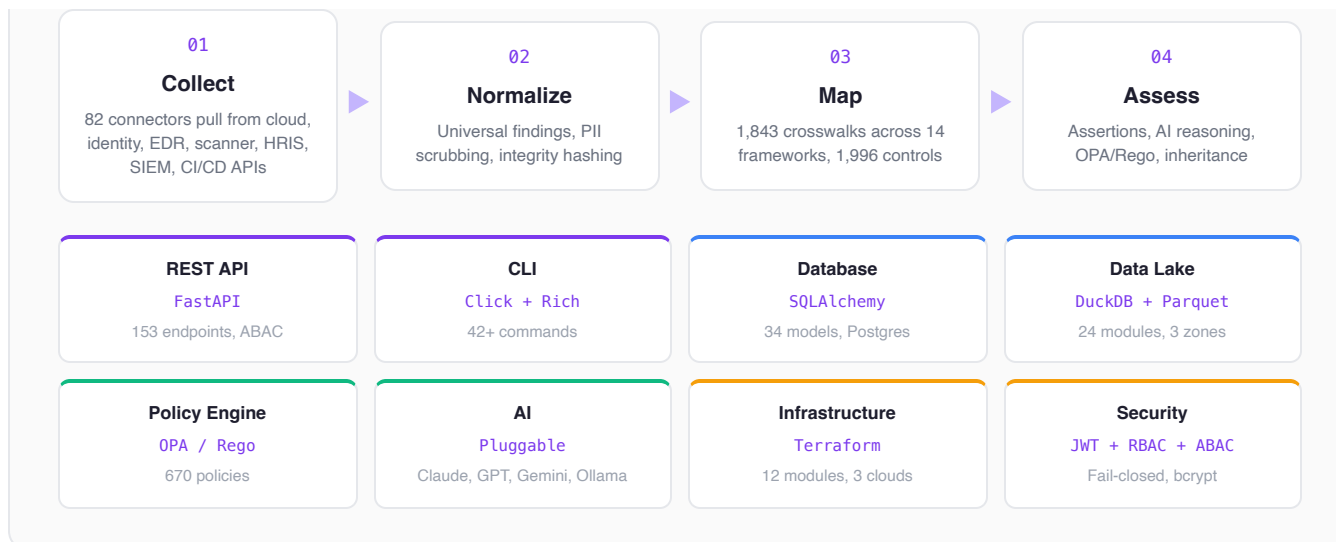
How the Pipeline Works

Evidence flows through four immutable stages. In the first stage, eighty-two source connectors pull security telemetry from cloud providers like AWS, Azure, and GCP; identity providers like Okta and Entra ID; endpoint detection platforms like CrowdStrike and SentinelOne; vulnerability scanners like Tenable, Qualys, and Wiz; code security tools like Snyk, Checkmarx, and Veracode; HRIS systems like Workday and BambooHR; SIEM platforms like Splunk and Sentinel; network security appliances from Palo Alto, Fortinet, and Zscaler; and dozens of other categories including CI/CD systems, MDM platforms, collaboration tools, email security gateways, and third-party risk scoring services. Each connector validates its configuration, verifies connectivity through a health check, and produces raw events that preserve the verbatim API response from the source system.

In the second stage, each raw event passes through a matching normalizer that transforms provider-specific data into a universal finding format called FindingData. An AWS IAM credential report, an Okta user directory, and an Entra ID export all become the same structured object, enabling cross-provider analysis. During normalization, Warlock automatically detects and scrubs personally identifiable information. Email addresses, names, social security numbers, and phone numbers are replaced with deterministic pseudonyms using SHA-256 hashing, so the same person always maps to the same pseudonym for correlation, but the actual identity is never stored. Every finding carries a boolean flag indicating whether PII was detected and removed. The database, the data lake, and every export are clean by default.

In the third stage, normalized findings are mapped to specific controls across all fourteen compliance frameworks using a crosswalk graph of 1,843 edges that link equivalent controls. A single finding about multi-factor authentication status can simultaneously map to NIST 800-53 AC-2, SOC 2 CC6.1, ISO 27001 A.8.5, HIPAA 164.312(d), and PCI DSS 8.3. Evidence collected for one framework automatically satisfies overlapping requirements in every other framework the organization is subject to.

In the fourth stage, a four-tier assessment model evaluates each control. The first tier consists of 101 deterministic assertion functions that perform fast, auditable, reproducible checks. The second tier is AI reasoning, where a large language model evaluates controls for which assertions are unavailable, subject to a configurable confidence floor that defaults to 0.7 and rejects unreliable assessments. The AI provider is pluggable, supporting Anthropic, OpenAI, Google Gemini, and Ollama for local inference. The third tier is 670 OPA/Rego policies that provide policy-as-code evaluation. The fourth tier is control inheritance, which propagates parent status to child enhancements following the FedRAMP CRM pattern.



Frameworks and Coverage

Warlock maps findings to 1,996 controls across fourteen compliance frameworks. The library covers NIST 800-53 Rev 5 with 1,176 controls spanning twenty families and their enhancements; ISO 27001:2022 with 93 Annex A controls; ISO 27701:2019 with 95 controls for privacy information management; ISO 42001:2023 with 39 controls for AI management; SOC 2 with 46 Trust Services Criteria; the Unified Compliance Framework with 115 controls mapping across all other frameworks; FedRAMP Moderate with 26 NIST 800-53 overlay controls; HIPAA Security Rule with 64 safeguard controls; CMMC Level 2 with 110 controls aligned with NIST 800-171; GDPR with 15 EU data protection controls; PCI DSS v4.0 with 63 payment card controls; NIST CSF 2.0 with 101 controls across six core functions; the EU AI Act with 33 high-risk AI controls; and SEC Cyber with 20 disclosure controls.

Cross-framework efficiency: The crosswalk graph connects equivalent controls with 1,843 edges. An organization pursuing SOC 2, ISO 27001, and HIPAA simultaneously collects evidence once and the pipeline maps it everywhere. The crosswalks are bidirectional and transitive, so adding a new framework immediately benefits from evidence already collected for others.

What the Platform Produces

Beyond continuous assessment results, Warlock provides several output mechanisms. OSCAL export generates machine-readable Assessment Results, System Security Plans, and Plans of Action and Milestones in OSCAL 1.1.2 format, the NIST standard for security automation. The audit evidence binder packages findings, control results, and supporting documentation into a ZIP archive organized by engagement. Remediation workflows track non-compliant controls through Plans of Action and Milestones with deadlines and assignment, compensating controls for situations where a primary control cannot be fully implemented, risk acceptances with Authorizing Official approval and expiration tracking, and issues auto-created from failing results with comment threads and assignment.

The GRC data lake provides an analytical layer built on DuckDB and Parquet files organized into three zones: raw events, enriched findings with control mappings, and curated domain-specific analytical tables. The lake supports TF-IDF semantic search for natural language compliance queries and batch AI assessment across the curated zone. A reconciliation engine compares the transactional database against the lake to verify data integrity.

Risk quantification uses a FAIR Monte Carlo engine to model risk in financial terms, a vendor risk scoring system that evaluates third-party exposure, and an audit simulation that projects compliance posture at a future date to answer questions like "if we audit on September 1, what will our posture look like?" Evidence sufficiency scoring identifies gaps before auditors do, and posture history tracking provides trend lines with effectiveness metrics including control uptime percentage, mean time to remediation, and drift detection counts.

Security Model

The security model defaults to deny at every layer. OPA policy gates block API requests that fail policy evaluation. Assertion evaluation fails controls when it encounters unexpected data rather than silently passing. ABAC scoping restricts what each user can see based on their framework, source, and control family permissions. If the policy engine is unreachable, access is denied. JWT authentication uses HS256 with a mandatory 32-character secret, passwords are hashed with bcrypt at 12 rounds, and accounts lock after five failed login attempts for thirty minutes. GDPR data subject rights are implemented through a GDPRManager that handles right of access, right to erasure with deterministic anonymization, and right to rectification. All AI prompts are sanitized to strip control characters and prevent evidence-block injection.

Who It Serves

Compliance teams use Warlock to run the pipeline, review assessment results, manage remediation workflows, and prepare for audits with pre-built evidence binders and sufficiency scoring that identifies gaps before auditors arrive. Security engineers configure connectors for their organization's tooling, write custom assertion functions for organization-specific controls, and define OPA policies for automated enforcement. CISOs and risk managers track compliance posture trends over time, quantify risk using FAIR methodology, monitor compliance drift with correlated change detection, and produce board-ready reporting from posture history and effectiveness metrics. Auditors verify the hash-chained audit trail independently, consume machine-readable OSCAL exports, and review evidence binders organized per engagement through a public trust portal that exposes compliance status to external parties.

The platform is written in Python 3.12+ and runs with a single Docker Compose command that starts PostgreSQL, Redis, OPA, runs database migrations, seeds demonstration data covering eighty-two connectors, over five thousand findings, and more than 373,000 control results, and starts the API server. For development, a shell script creates a virtual environment and seeds data using SQLite with no external dependencies.